

XWorm RAT – Malware Analysis Report

DFIR Report – Phishing-delivered .NET RAT (CyberDefenders #247)

Yanis Lounadi, Julien Laborie

2026-06-05

Contents

Executive Summary	2
Investigation & Technical Analysis	2
Technical Incident Overview	2
Scope & Methodology	2
Systèmes investigués	2
Artefacts analysés	2
Outils utilisés	3
Approche méthodologique	3
Detailed Findings	3
Identification	3
Anti-analyse (T1497, T1622)	3
Configuration chiffrée (AES) & C2	4
Persistance & privilèges (T1547.001, T1053.005, T1059.001)	4
Évasion défensive (T1562.001, T1564.001, T1112)	4
Propagation USB (T1091)	4
Collecte (T1056.001, T1115)	4
Root Cause Analysis	4
Indicators of Compromise	5
Attack Chain Reconstruction	6
Impact Analysis	6
Remediation & Recommendations	6
Actions immédiates (24 heures)	6
Actions à court terme (1 semaine)	7
Actions à long terme (1 mois)	7
Appendices	7
A. Hashes forensiques de l'artefact	7
B. Commandes d'analyse exécutées	7
C. Tableau de synthèse des réponses (CyberDefenders #247)	8
D. Références MITRE ATT&CK	8

Executive Summary

Un employé a exécuté une pièce jointe malveillante reçue par e-mail de phishing, se présentant comme un installateur **Adobe** (« Adobe Installer », signé en apparence « Adobe Inc. »). Le fichier est en réalité un **RAT XWorm** (.NET, ~85 Ko), exécuté silencieusement et provoquant un comportement système anormal.

L'analyse statique et la décompilation complète de l'échantillon ont permis de reconstituer l'intégralité de ses capacités : **anti-analyse** (5 vérifications anti-VM/anti-debug/anti-sandbox), **persistance** triple (copie dans %AppData%\WmiPrvSE.exe, raccourci Startup, clé Run, tâche planifiée à privilèges élevés), **évasion défensive** (exclusions Windows Defender, masquage des fichiers, auto-protection par processus critique), **propagation USB**, **keylogging** et **clipper crypto-monnaie**. La configuration, chiffrée en **AES**, a été déchiffrée et révèle trois serveurs de commande et contrôle (C2) communiquant sur le port **7000**.

Impact : compromission complète du poste, vol d'identifiants (keylogger), risque de détournement de transactions crypto (clipper), propagation latérale via supports amovibles, et contrôle distant total de la machine par l'attaquant.

Recommandations critiques : isoler le poste, supprimer les mécanismes de persistance, bloquer les IOC réseau (C2) sur l'ensemble du parc, révoquer les identifiants saisis depuis l'infection, et renforcer le filtrage des pièces jointes e-mail.

Investigation & Technical Analysis

Technical Incident Overview

L'artefact unique de cette investigation est un binaire malveillant (XWorm.malware) téléchargé depuis un e-mail de phishing. Il s'agit d'un assembly .NET 32 bits, non packé mais fortement obfusqué (noms aléatoires), dont les métadonnées usurpent l'identité d'Adobe pour gagner la confiance de l'utilisateur. L'échantillon appartient à la famille **XWorm**, un RAT commercial largement diffusé (lignée NjRAT/Quasar) offrant prise de contrôle distante, vol de données et modules complémentaires.

Scope & Methodology

Systèmes investigués

Poste de travail Windows d'un employé, infecté après ouverture d'une pièce jointe de phishing. L'analyse porte exclusivement sur l'échantillon malware fourni (analyse statique approfondie).

Artefacts analysés

Artefact	Fichier	Description
Échantillon malware	artifacts/ XWorm.malware	PE32 .NET, 85 Ko, XWorm RAT

Outils utilisés

Catégorie	Outils
Identification PE	file, pefile, Detect It Easy, CFF Explorer, PEStudio
Décompilation .NET	ILSpy / ilspycmd, dnSpy
Métadonnées .NET	dnfile
Cryptographie	Python pycryptodome (reproduction du déchiffrement AES)
Dynamique (référence)	ProcMon, RegShot

Approche méthodologique

1. Identification du fichier, calcul des empreintes, lecture des ressources de version.
2. Décompilation complète en C# et cartographie des classes/méthodes malgré l'obfuscation.
3. Identification du schéma de chiffrement de configuration et reproduction du déchiffrement.
4. Analyse du flux d'exécution : anti-analyse, persistance, évocation, propagation, collecte.
5. Cartographie des comportements sur MITRE ATT&CK et consolidation des IOC.

Detailed Findings

Identification

```
# file XWorm.malware
PE32 executable (GUI) Intel 80386 Mono/.Net assembly, for MS Windows
# SHA256
ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af
# MD5
7c7aff561f11d16a6ec8a999a2b8cdad
# Assembly : xWmDDA 2.12.0.20 | Compilation (UTC) : 2024-02-25 22:53:40
```

Les ressources de version usurpent Adobe : CompanyName = "Adobe Inc.", ProductName = "Adobe Installer", LegalCopyright = "© 2015-2023 Adobe. All rights reserved."

Anti-analyse (T1497, T1622)

Une fonction de garde évalue **5 vérifications** ; toute condition vraie déclenche Environment.FailFast(null) :

1. **VM** via WMI Win32_ComputerSystem (microsoft corporation + VIRTUAL, vmware, VirtualBox) ;
2. **Débogueur** via CheckRemoteDebuggerPresent ;
3. **Sandboxie** via GetModuleHandle("SbieDll.dll") ;
4. **Windows XP** via ComputerInfo.OSFullName ;
5. **Hébergement / cloud** via http://ip-api.com/line/?fields=hosting.

Configuration chiffrée (AES) & C2

La configuration est chiffrée en **AES** (RijndaelManaged, ECB, PKCS7). La clé de 32 octets est dérivée du MD5 de la chaîne codée en dur **8xTJ0EKPuIQsJVat**, copié deux fois dans un buffer (avec un chevauchement à l'offset 15). Le déchiffrement révèle :

Paramètre	Valeur
C2 (Hosts)	185.117.250.169, 66.175.239.149, 185.117.249.43
Port	7000
Splitter / mutex	<Xwormmm>
Groupe	Default
Install	%AppData%\WmiPrvSE.exe
Copie USB	USB.exe
Clipper BTC	bc1q2a4jgxmvslng5khvzkt9pechms20ghff42s5g
Clipper ETH	0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5

Persistence & privilèges (T1547.001, T1053.005, T1059.001)

- Copie dans %AppData%\WmiPrvSE.exe (usurpation du *WMI Provider Host*) ;
- Raccourci WmiPrvSE.lnk dans le dossier Startup ;
- Clé HKCU\...\CurrentVersion\Run\WmiPrvSE ;
- Tâche planifiée WmiPrvSE : schtasks /create /f /RL HIGHEST /sc minute /mo 1 (exécution chaque minute, privilèges les plus élevés).

Évasion défensive (T1562.001, T1564.001, T1112)

- Exclusions Windows Defender via PowerShell (Add-MpPreference -ExclusionPath/-ExclusionProcess) ;
- ShowSuperHidden = 0 sous Explorer\Advanced pour masquer les fichiers protégés ;
- RtlSetProcessIsCritical (NTdll) pour rendre le processus non-killable (BSOD à la terminaison).

Propagation USB (T1091)

Détection des lecteurs Removable, auto-copie en USB.exe et dépôt de leurres .lnk ciblant cmd.exe pour relancer la charge tout en masquant les fichiers originaux.

Collecte (T1056.001, T1115)

- **Keylogger** : hook clavier bas niveau via SetWindowsHookEx (+ ToUnicodeEx, GetKeyboardState, enregistrement de la fenêtre active) ;
- **Clipper crypto** : remplacement d'adresses BTC/ETH/TRC20 dans le presse-papiers.

Root Cause Analysis

Le point d'entrée est l'**ouverture d'une pièce jointe de phishing** par un utilisateur. L'absence de filtrage efficace des pièces jointes exécutables et l'exécution sans contrôle applicatif (pas de

liste blanche / AppLocker) ont permis le déclenchement de la charge. L'usurpation visuelle d'un installateur Adobe a renforcé la crédibilité du leurre.

Indicators of Compromise

Type	Valeur
SHA256	ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af
MD5	7c7aff561f11d16a6ec8a999a2b8cdad
C2	185.117.250.169:7000, 66.175.239.149:7000, 185.117.249.43:7000
Mutex / splitter	<Xwormmm>
Fichier	%AppData%\WmiPrvSE.exe
Persistence	WmiPrvSE.lnk (Startup), HKCU\...\Run\WmiPrvSE, tâche planifiée WmiPrvSE
Spread USB	USB.exe + leurres *.lnk
URL anti-analyse	http://ip-api.com/line/?fields=hosting
Clipper BTC	bclq2a4jgxmvslng5khwvzkt9pechms20ghff42s5g
Clipper ETH	0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5

Attack Chain Reconstruction

Étape	Action	MITRE ATT&CK
1	Réception et ouverture de la pièce jointe de phishing	T1566.001
2	Exécution du faux « Adobe Installer » (.NET)	T1204.002 / T1036
3	Vérifications anti-VM/anti-debug/anti-sandbox	T1497 / T1622
4	Copie %AppData%\WmiPrvSE.exe + Startup + Run + tâche planifiée	T1547.001 / T1053.005
5	Exclusions Defender, masquage, processus critique	T1562.001 / T1564.001
6	Déchiffrement AES de la config et connexion C2 (:7000)	T1573 / T1071
7	Keylogging + clipper crypto	T1056.001 / T1115
8	Propagation par périphériques amovibles	T1091

Impact Analysis

L'infection donne à l'attaquant un **contrôle distant complet** du poste. Les conséquences directes : vol d'identifiants et de données saisies au clavier, détournement potentiel de transactions crypto-monnaie (clipper), possibilité d'exécution de commandes/plugins arbitraires, attaques DDoS, et **propagation** vers d'autres postes via clés USB. L'auto-protection (processus critique) et les exclusions Defender compliquent la remédiation et augmentent la persistance de la menace.

Remediation & Recommendations

Actions immédiates (24 heures)

- Isoler le poste du réseau (déconnexion physique/logique).
- Bloquer les IP C2 (185.117.250.169, 66.175.239.149, 185.117.249.43) en sortie sur le parc.
- Supprimer la persistance : tâche WmiPrvSE, clé Run WmiPrvSE, %AppData%\WmiPrvSE.exe, WmiPrvSE.lnk (Startup). Lever d'abord le flag processus critique avant terminaison.

- Réinitialiser ShowSuperHidden et retirer les exclusions Defender ajoutées.

Actions à court terme (1 semaine)

- Révoquer/réinitialiser tous les identifiants saisis depuis l'infection (keylogger).
- Scanner les supports amovibles (USB, exe, leurres .lnk) sur l'ensemble de l'organisation.
- Déployer des règles de détection (IOC, hash, comportements schtasks/Add-MpPreference).

Actions à long terme (1 mois)

- Filtrage renforcé des pièces jointes (blocage des exécutables, sandboxing e-mail).
- Liste blanche applicative (AppLocker / WDAC) et restriction de l'exécution depuis %AppData%.
- Désactivation de l'autorun USB et sensibilisation des utilisateurs au phishing.

Appendices

A. Hashes forensiques de l'artefact

Fichier	SHA256	MD5
XWorm.malware	ed525f030c76834184b4e194077c8c4e7342b33235743f551f49435a9a089299a2b8cdad	35743f551f49435a9a089299a2b8cdad

B. Commandes d'analyse exécutées

```
# Identification
file XWorm.malware
sha256sum XWorm.malware && md5 XWorm.malware

# Timestamp de compilation (PE header)
python3 -c "import
pefile,datetime;pe=pefile.PE('XWorm.malware');print(datetime.datetime.utcnow().timestamp(pe.FILE_HEADER.TimeDateStamp))"

# Décompilation .NET complète
ilspycmd XWorm.malware > xworm_decompiled.cs

# Déchiffrement AES de la configuration (clé = MD5("8xTJ0EKPuiQsJVat"))
python3 decrypt_config.py # cf. docs/config_extraction.md
```

C. Tableau de synthèse des réponses (CyberDefenders #247)

#	Question	Réponse
Q1	Timestamp de compilation (UTC)	2024-02-25 22:53
Q2	Société usurpée	Adobe
Q3	Nombre de checks anti-analyse	5
Q4	Tâche planifiée	WmiPrvSE
Q5	Binaire déposé dans AppData	WmiPrvSE.exe
Q6	Algorithme de chiffrement	AES
Q7	Chaîne codée en dur (clé/IV)	8xTJ0EKPuiQsJVat
Q8	IP C2	185.117.250.169, 66.175.239.149, 185.117.249.43
Q9	Port C2	7000
Q10	Copie USB	USB.exe
Q11	Extension des fichiers créés	.lnk
Q12	DLL de détection sandbox	SbieDll.dll
Q13	Clé de registre (éléments cachés)	ShowSuperHidden
Q14	API processus critique	RtlSetProcessIsCritical
Q15	API hooks clavier	SetWindowsHookEx
Q16	Fonctionnalité principale	Keylogger

D. Références MITRE ATT&CK

T1566.001, T1204.002, T1036, T1497, T1622, T1547.001, T1053.005, T1059.001, T1562.001, T1564.001, T1112, T1091, T1573, T1071, T1056.001, T1115.